Project progress 02-04-2026

Rolfe • April 3, 2026 • Estimated reading time: 2 min

What

This week I searched Cross-Site-Reforgery-Requests (CSRF) to understand what they do, how hackers create them and how to prevent them from happening. After the research, I added a CSRF token generator to the application; the token is generated after login and will be stored in the session. I added an hidden input to each form that the user can use to make changes to the database, the hidden input contains the generated token. Before any update in the database happens, the token submitted by the user will be compared with the token generated by the server; if they match, the update will happen otherwise, the request will be rejected. Furthermore, to ensure that the pages were protected, I created a webpage that contains a generic CRSF form and used it to test my website.

So What

During the research I learned that sessions carrying data across the pages can be exploited. A hacker can easily create a malicious webpage with a form that asks the victim to send money to their account. If the victim somehow visits the malicious webpage, the malicious form could be submitted automatically and their money would be transferred to the hacker. Since the user's session cookies were still valid the transaction would go undetected. All of this can happen if the user clicks on a suspicious link found in their email inbox, or if the hacker finds a way to inject the link in one of the webpages of the website. Understanding this vulnerability highlighted the importance of validating the origin of requests and implementing CSRF tokens to ensure that only intentional user actions are processed.

Now What

Following the implementation of CSRF protection, I plan to further strengthen the security of the application. The next steps include implementing protections against replay attacks and introducing rate limiting to reduce repeated login attempts. These improvements will enhance the overall security of the application and help mitigate common web-based attack.